

Diretrizes de Segurança Normativas (Anti-Regressão)

Projeto: Conheça Farmácia • **Alvo:** Agentes Autônomos (Antigravity/O Sentinela) e Engenheiros de Software • **Data de Aplicação:** Maio de 2026 • **Versão:** 1.0.0 (Pós-Auditoria)

Este documento estabelece as diretrizes normativas de segurança para o repositório do projeto **Conheça Farmácia**. Após a auditoria estrutural de maio de 2026, onde foram mitigados 100% dos riscos críticos mapeados pelo agente *O Sentinela*, a leitura e conformidade estrita com este manual é **obrigatória** antes de qualquer modificação, refatorização ou introdução de novas funcionalidades.

ORDEM IMPERATIVA PARA AGENTES DE IA: É proibido ignorar as funções de sanitização centralizadas em `src/lib/security.js`. Qualquer reintrodução de código que contorne estas diretrizes resultará na rejeição automática do commit na pipeline de integração contínua.

1. Matriz de Diretrizes Técnicas Obrigatórias

ID Norma	Contexto & Padrão Proibido	Ação Corretiva Exigida / Solução Padrão
SEC-XSS-01	Uso de <code>innerHTML</code> ou interpolações brutas de variáveis vindas da base de dados (Supabase) em elementos HTML dinâmicos.	Obrigatório envolver a variável na função <code>escapeHtml(variavel)</code> importada de <code>src/lib/security.js</code> . Exceção única: Renderização de Markdown previamente tratada por <code>DOMPurify</code> .
SEC-XSS-02	Interpolação de dados dinâmicos dentro de atributos HTML (ex: <code>value="\$ {variavel}"</code> , <code>id="..."</code>) em formulários de administração.	Obrigatório aplicar a função <code>escapeAttr(variavel)</code> para neutralizar quebras de aspas e injeções de eventos DOM (ex: <code>onfocus</code>).
SEC-AUTH-01	Implementação de lógica local de validação de sessão (ex: <code>checkAuth()</code> isolados por ficheiro) nas páginas do painel administrativo.	Proibido duplicar lógica. Toda e qualquer validação de segurança e estado de privilégios de administrador deve ser importada e aguardada centralmente a partir de <code>auth.js</code> .
SEC-DATA-01	Exposição de chaves de infraestrutura (<code>SUPABASE_URL</code> , <code>SUPABASE_ANON_KEY</code>) ou instâncias globais no objeto <code>window</code> .	Toda a comunicação deve ser encapsulada em módulos fechados. Utilizar estritamente o <code>supabaseClient</code> exportado por <code>config.js</code> e variáveis locais controladas pelo Vite (<code>import.meta.env</code>).
SEC-UPL-01	Upload de ficheiros de imagem (banners, logótipos de eventos, avatares) sem verificação explícita de metadados no cliente.	Intercetar o upload e submeter o ficheiro à função <code>validateImage(file)</code> . Bloquear ficheiros > 5MB e tipos MIME fora do ecossistema seguro (JPEG, PNG, WebP, GIF). Bloqueio estrito a vetores SVG não sanitizados.
SEC-SUP-01		Todas as tags <code><script></code> externas devem conter os atributos Subresource Integrity (SRI) com o respetivo

ID Norma	Contexto & Padrão Proibido	Ação Corretiva Exigida / Solução Padrão
	Inclusão de scripts ou dependências externas via CDN através de tags simples de marcação.	hash criptográfico <code>integrity="sha384-..."</code> e <code>crossorigin="anonymous"</code> .
SEC-DB-01	Criação ou modificação de tabelas com dados de utilizadores/utentes (ex: inscrições, newsletters) com políticas RLS permissivas.	As políticas de Row Level Security (RLS) devem rejeitar pedidos anónimos (<code>USING (false)</code> para SELECT público). O acesso aos dados pessoais deve exigir validação de perfil de administrador associado a <code>admin_users</code> .

2. Assinatura das Funções da Vacina Universal (`src/lib/security.js`)

Estas funções são os alicerces de proteção do frontend do Conheça Farmácia. Devem ser preservadas e expandidas apenas sob supervisão de arquitetura:

```
// src/lib/security.js

/**
 * Escapa caracteres HTML para prevenir XSS no corpo do DOM.
 */
export function escapeHtml(unsafe) {
  if (!unsafe) return '';
  return unsafe
    .toString()
    .replace(/&/g, "&")
    .replace(/>/g, ">")
    .replace(/"/g, "\"")
    .replace(/'/g, "'");
}

/**
 * Escapa caracteres para injeção segura em atributos de tags HTML.
 */
export function escapeAttr(unsafe) {
  if (!unsafe) return '';
  return unsafe
    .toString()
    .replace(/&/g, "&")
    .replace(/"/g, "\"")
    .replace(/'/g, "'")
    .replace(/>/g, ">");
}

/**
 * Garante que caminhos de redirecionamento ou links externos usam protocolos seguros.
 */
export function validateUrl(url) {
  if (!url) return '#';
  return url.startsWith('http://') || url.startsWith('https://') ? url : '#';
}
```

3. Checklist Pré-Voo para Agentes (Prompt de Execução)

Antes de submeter qualquer alteração de código neste repositório, o agente deve correr mentalmente a seguinte validação de conformidade:

1. **Estou a renderizar texto dinâmico?** Se sim, certifiquei-me de que não usei `innerHTML` puro com variáveis sem `escapeHtml()` ?
2. **Estou a manipular um formulário administrativo?** Os novos campos criados dinamicamente utilizam `escapeAttr()` nos seus atributos de valor?
3. **A introdução de código requer novos logs?** Removi todos os `console.log` que imprimem objetos de resposta de bases de dados ou estruturas de erro internas em produção?
4. **Estou a ligar-me ao Supabase?** Garanti que reutilizei o cliente central instanciado (`supabaseClient`) em vez de tentar criar uma nova ligação local com chaves expostas?

Nota de Governação de Código: O cumprimento destas normas garante que a equipa do *Conheça Farmácia*, atualmente constituída por 16 membros, mantenha a integridade clínica e operacional do ecossistema de saúde digital sem risco de quebras de segurança ou fugas de dados.